

CYBER SECURITY INCIDENT REPORT ANALYZING NETWORK ATTACKS

SCENARIO:

You work as a security analyst for a travel agency that advertises sales and promotions on the company's website. The employees of the company regularly access the company's sales webpage to search for vacation packages their customers might like.

One afternoon, you receive an automated alert from your monitoring system indicating a problem with the web server. You attempt to visit the company's website, but you receive a connection timeout error message in your browser.

You use a packet sniffer to capture data packets in transit to and from the web server. You notice a large number of TCP SYN requests coming from an unfamiliar IP address. The web server appears to be overwhelmed by the volume of incoming traffic and is losing its ability to respond to the abnormally large number of SYN requests. You suspect the server is under attack by a malicious actor.

You take the server offline temporarily so that the machine can recover and return to a normal operating status. You also configure the company's firewall to block the IP address that was sending the abnormal number of SYN requests. You know that your IP blocking solution won't last long, as an attacker can spoof other IP addresses to get around this block. You need to alert your manager about this problem quickly and discuss the next steps to stop this attacker and prevent this problem from happening again. You will need to be prepared to tell your boss about the type of attack you discovered and how it was affecting the web server and employees.

Section 1:

One potential explanation for the website's connection timeout error message is:

The server may have been targeted by a Denial-of-Service (DoS) attack, specifically a SYN flood attack.

The logs show that:

A large number of TCP SYN requests were sent to the server from an unfamiliar IP address. These SYN requests were not followed by the proper TCP handshake completion.

This event could be:

A SYN flood attack, which is a type of DoS attack. The attacker floods the server with SYN requests, causing the server to become overwhelmed and unable to handle legitimate traffic.

Section 2:

When website visitors try to establish a connection with the web server, a three-way handshake occurs using the TCP protocol. Explain the three steps of the handshake:

SYN – The client sends a SYN (synchronize) packet to the server to request a connection.

SYN-ACK – The server responds with a SYN-ACK (synchronize-acknowledge) packet to acknowledge the request.

ACK – The client responds back with an ACK (acknowledge) packet to establish the connection fully.

The server tries to respond to each SYN packet with a SYN-ACK and waits for the final ACK from the client. But in a SYN flood, the attacker never sends the ACK. This causes the server to hold open the half-formed connections, using up its memory and resources. Eventually, the server becomes too full and can't accept new legitimate connections.

The logs showed a massive amount of SYN requests from a single IP address, which is abnormal. This caused the server to be overwhelmed with half-open connections, leading to a timeout error when employees or customers tried to access the website. It also stopped legitimate users from connecting to the website, affecting business operations.

Actions Taken:

- Took the web server offline temporarily to allow it to recover.
- Blocked the IP address that was sending the abnormal SYN requests using the company's firewall.
- Acknowledged that IP blocking is a short-term solution as attackers can spoof other IP addresses.

Next Steps:

- Implement a rate-limiting rule or intrusion prevention system (IPS) to detect and stop SYN floods early.
- Configure the server with SYN cookies to manage half-open connections more efficiently.
- Consider using a web application firewall (WAF) or a DDoS protection service (like Cloudflare or AWS Shield) to add stronger layers of defense.
- Monitor network logs continuously and set up automated alerts for unusual traffic patterns.

Conclusion:

This incident showed how a SYN flood attack can impact website availability. As a cybersecurity analyst, identifying the type of attack and taking immediate action helped minimize the damage. Going forward, adding stronger prevention tools and improving monitoring can help protect against similar threats.